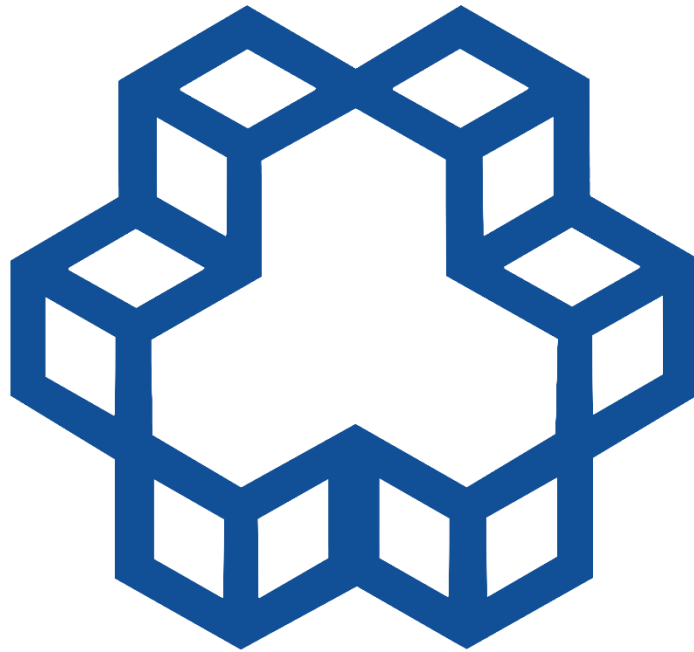


Computer Networking 2

Spring 2026



Student Name:

Ali Kashi Pazha

Student ID:

40121723

Instructor:

Dr. Yaeghoobi

Ransomware Attack Simulation in a Controlled Lab

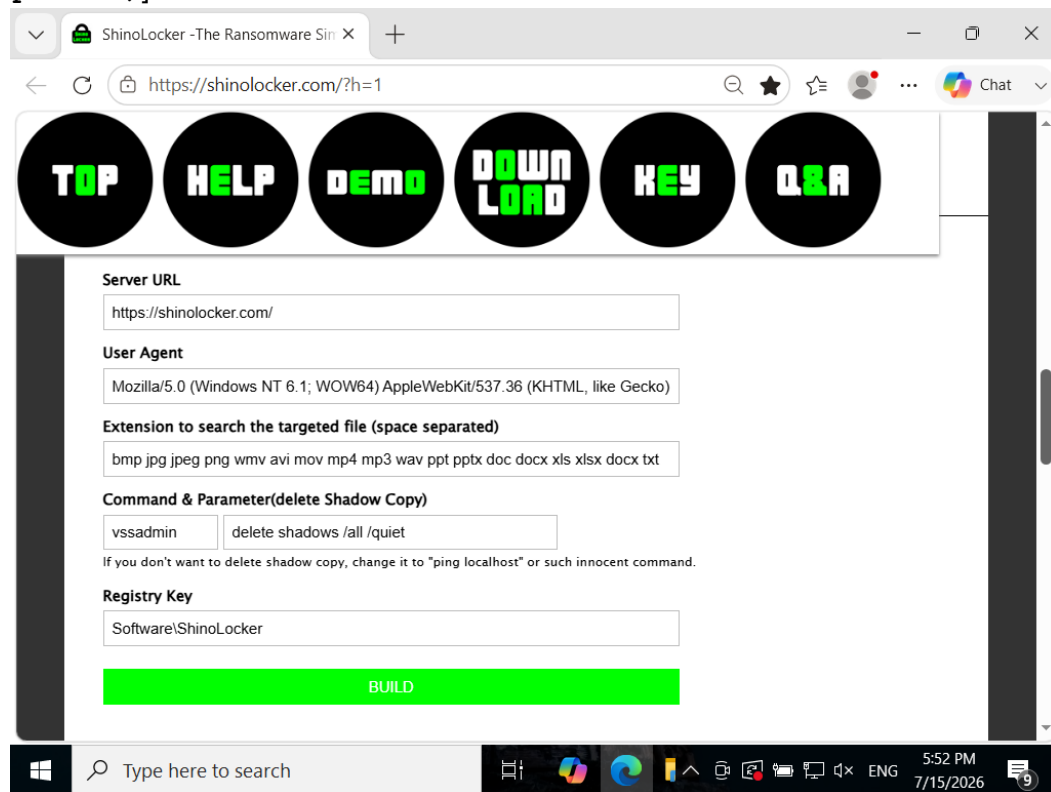
1. Building The Lab (Instructions)

1.1. Setup

- 1) Build an isolated virtual machine (For a controlled lab, we must simulate the ransomware attack in an isolated system. Therefore, **proceed in the virtual machine**).
- 2) Download and install [Wireshark\(Windows x64\)](#). (Provided in [.\Lab\Wireshark.3.6.8.x86.rar] directory (x32 version))
- 3) Download [Procmon\(Windows\)](#). (Provided in [.\Lab\ProcessMonitor.zip] directory)
- 4) Turn off all the [virus & threat protection] and [firewall & network protection] settings.
- 5) Build [ShinoLocker](#). (Provided in [.\Lab\ShinoLocker.rar] directory)

1.2. How to Build ShinoLocker

- 1) Click on [this](#). Then scroll down to [DOWNLOAD].
- 2) Add [txt] at the end of the [Extension to search the targeted file (space separated)] textbox.



The screenshot shows a web browser window with the URL <https://shinolocker.com/?h=1>. The page features a navigation bar with buttons: TOP, HELP, DEMO, DOWNLOAD, KEY, and Q&A. Below the navigation bar is a configuration form with the following fields:

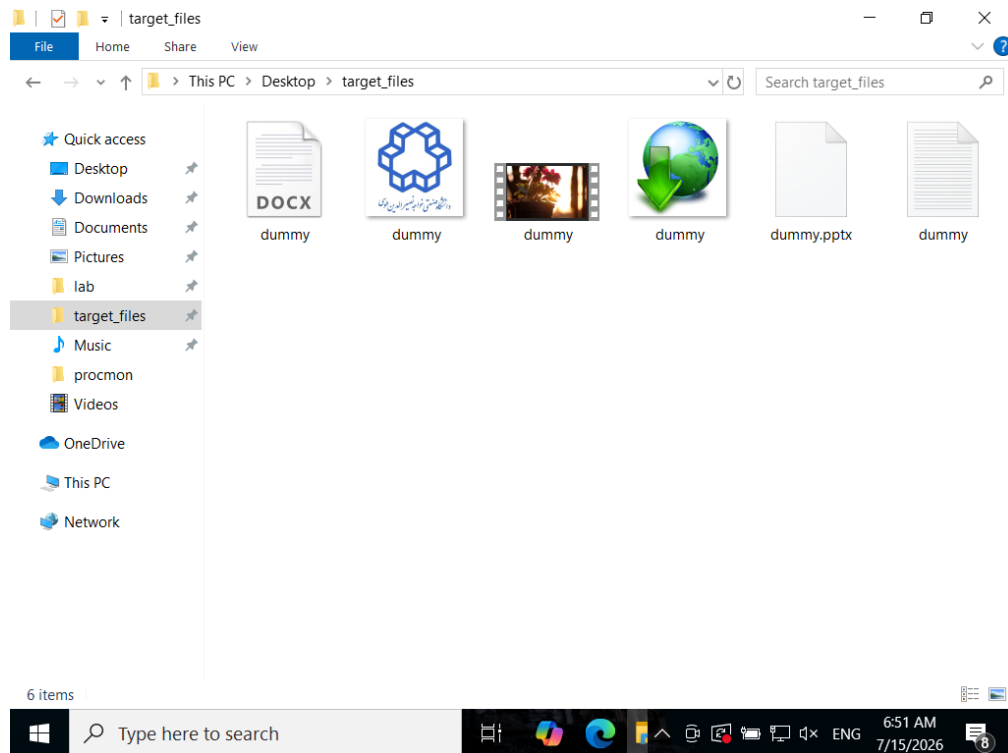
- Server URL**:
- User Agent**:
- Extension to search the targeted file (space separated)**:
- Command & Parameter(delete Shadow Copy)**:
If you don't want to delete shadow copy, change it to "ping localhost" or such innocent command.
- Registry Key**:

At the bottom of the form is a large green button labeled **BUILD**.

- 3) Click [BUILD].

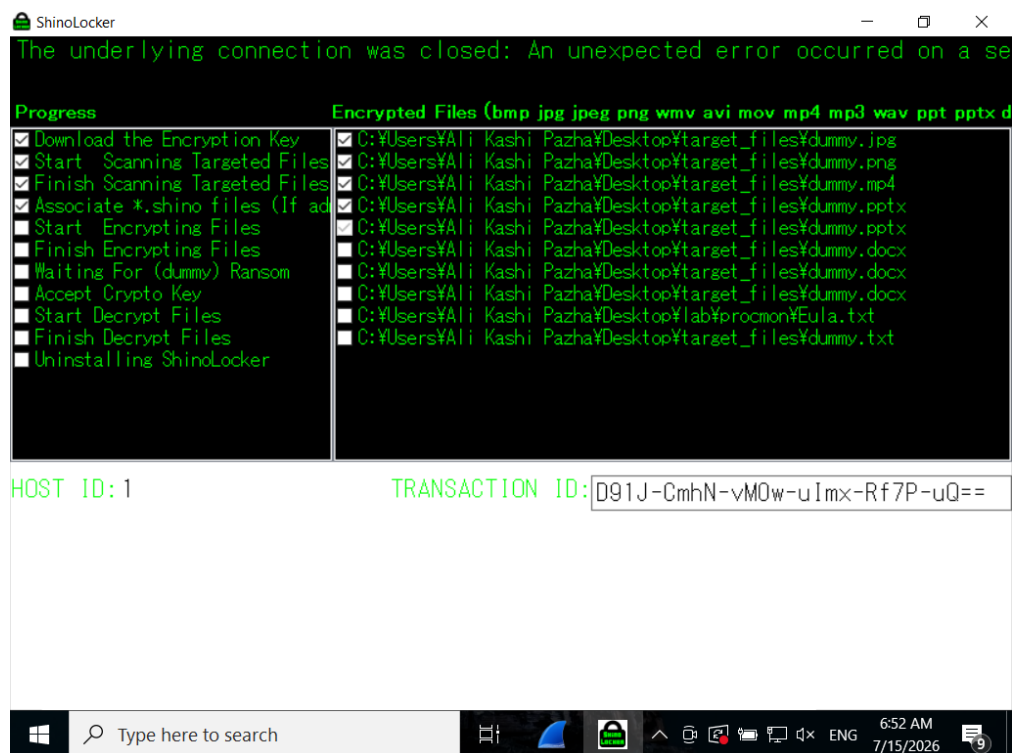
1.3. Build a Target Folder

- 1) Make a [target_files] folder.
- 2) Fill it with a bunch of target files (formatted [txt], [docx], [pptx], [mp4], [jpg], [png], etc.)

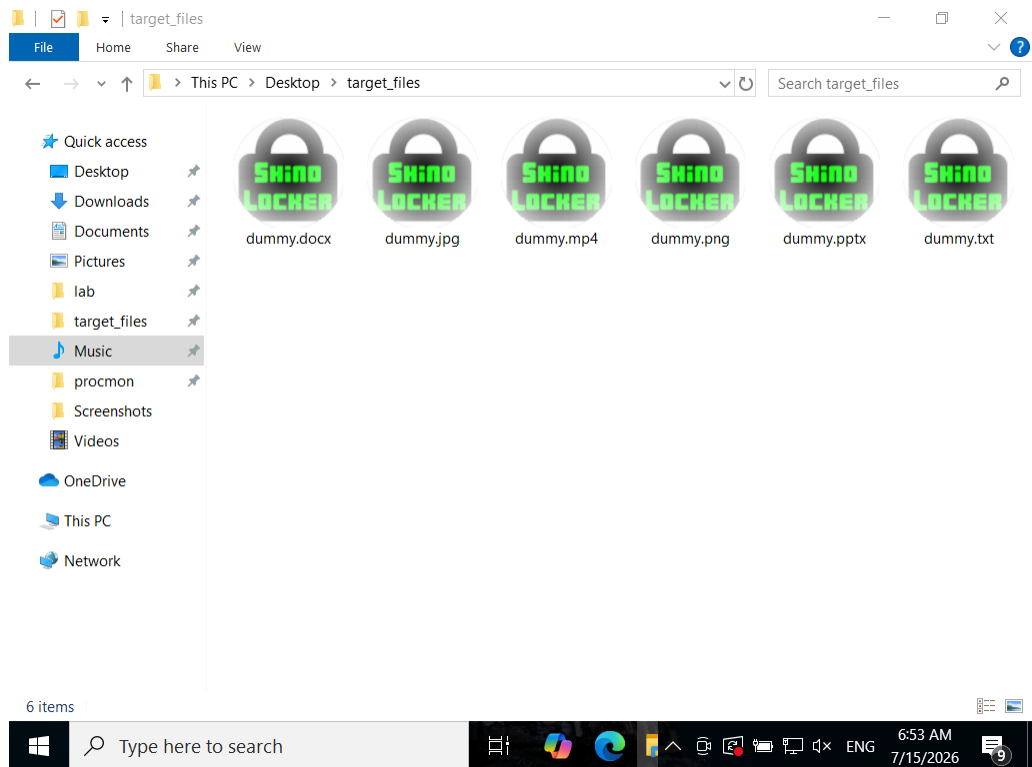


1.4. Start the Simulation and Log Events

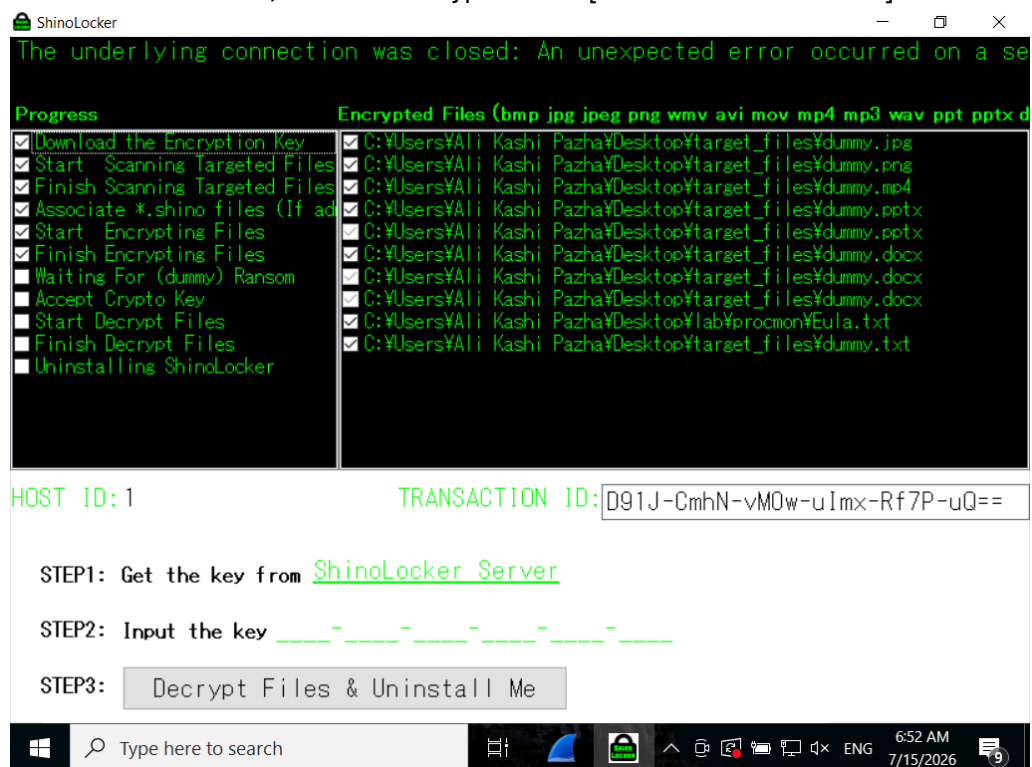
- 1) Open Procmon. Stop the capturing and clear the events.
- 2) Open Wireshark. Start capturing the [Ethernet], then go back to Procmon and start capturing immediately.
- 3) Start the ShinoLocker.



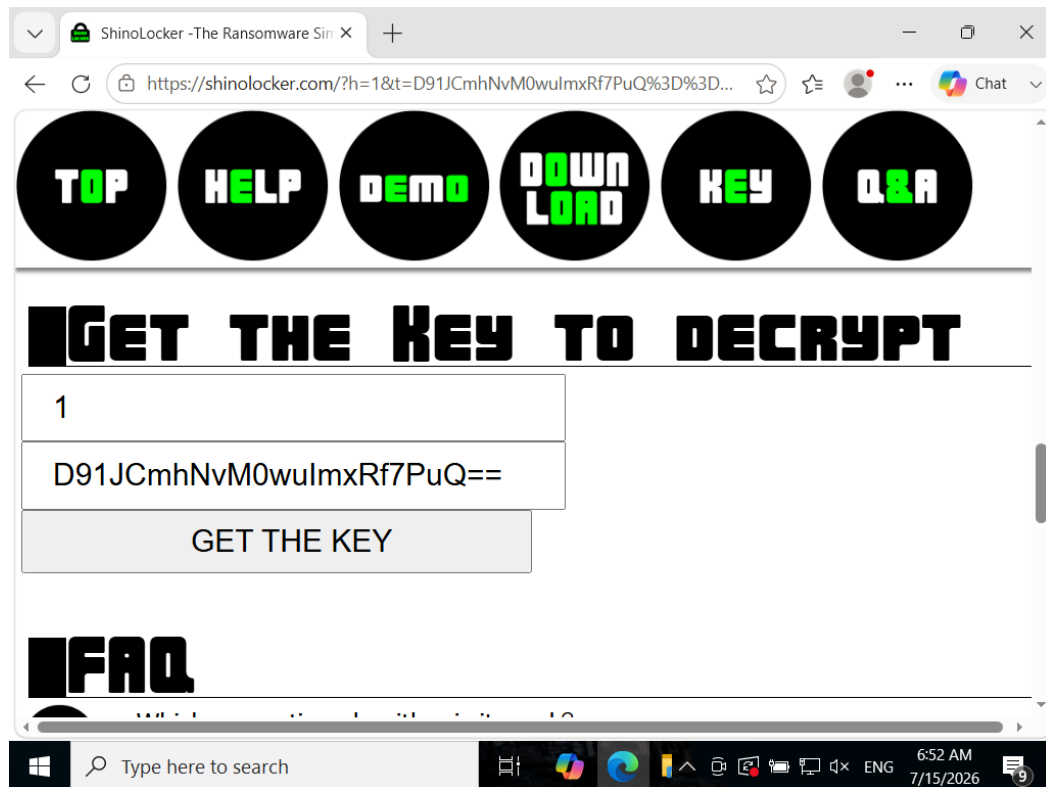
- 4) When the Encryption is done, check the [target_files] folder. Can you open your files?



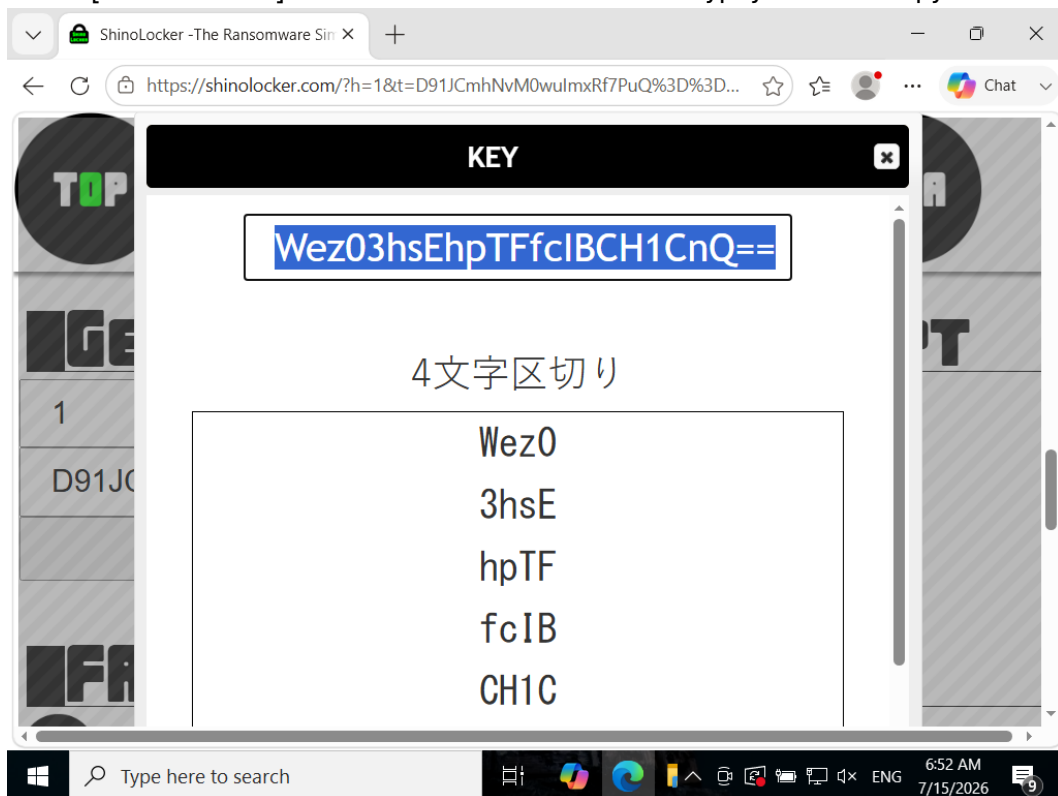
- 5) Back to the ShinoLocker, click on the hyperlinked [**ShinoLocker Server**].



- 6) Scroll down to the [**GET THE KEY TO DECRYPT**] part. You'll notice the HOST ID and TRANSACTION ID textboxes are filled with your [HOST ID] and [TRANSACTION ID].



- 7) Click on **[GET THE KEY]** button. You'll see the KEY to decrypt your files. Copy it.



- 8) Go back to ShinoLocker. Paste the clipboard in the provided space (**[STEP 2]**). Then click on the **[Decrypt Files & Uninstall Me]** button.

2. Introduction to Data and Network Security

In today's connected world, protecting information from unauthorized access, modification, and destruction is a core pillar of Information Technology. In this section, we first examine the fundamental concepts of cryptography, which form the core of data security and the primary mechanism of ransomware, and then investigate the ShinoLocker ransomware simulator and its behavioral patterns.

2.1. Fundamentals of Cryptography

Cryptography is the science and art of hiding information so that only authorized individuals can read it. Ransomware utilizes these exact cryptographic mechanisms, but for malicious purposes, to make the victim's files inaccessible. To understand this process, we must be familiar with the following basic concepts and variables:

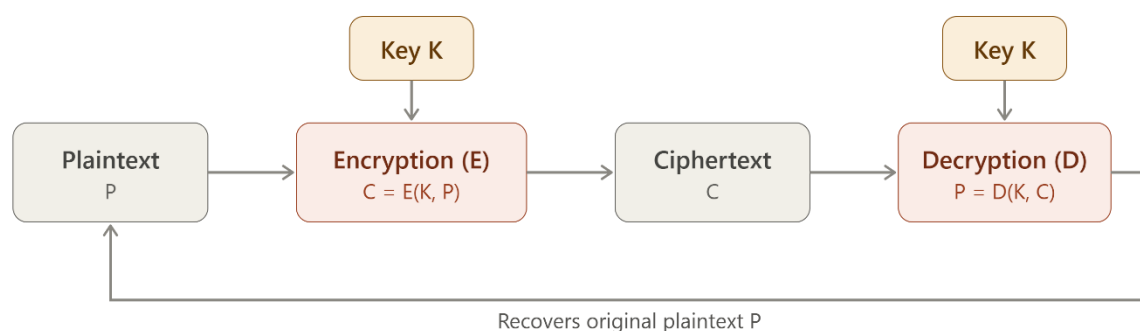
- **Plaintext (P):** The original user data and files that are readable and usable in their normal state (e.g., text files, images, and databases).
- **Ciphertext (C):** Data that has been transformed into an unreadable and meaningless format after applying cryptographic algorithms.
- **Key (K):** A string of random or pseudo-random data used as an input parameter in cryptographic algorithms. The security of the entire system depends on keeping this key confidential.
- **Encryption Algorithm (E):** A mathematical function that converts plaintext (P) into ciphertext (C) using the key (K). Its mathematical relationship is:

$$C = E(K, P)$$

- **Decryption Algorithm (D):** The inverse mathematical function that reverts the ciphertext (C) back into plaintext (P) using the key (K). Its mathematical relationship is defined as:

$$P = D(K, C)$$

In ransomware attacks, the attacker locates the system files (P) and executes function E using a key (K) that only they possess, converting the files into C . To execute function D and recover their files, the victim needs the key K , which the attacker sells in exchange for a ransom.



2.2. What is Ransomware?

Ransomware is a sophisticated class of malicious software (malware) designed to deny a user or organization access to their files, systems, or networks until a ransom is paid. It achieves this by employing advanced cryptographic techniques to encrypt the victim's data, rendering it inaccessible without the corresponding decryption key held by the attacker.

Modern ransomware operations typically follow a distinct lifecycle:

- 1) **Infection and Execution:** The malware infiltrates the system through vectors such as phishing emails, exploit kits, or compromised credentials.
- 2) **Command and Control (C2) Communication:** Once active, the ransomware establishes a secure, often encrypted, connection to the attacker's C2 servers to exchange cryptographic keys (e.g., sending a unique HOST ID and receiving a public encryption key).
- 3) **Encryption:** The malware systematically searches for valuable file extensions and encrypts them, often deleting Volume Shadow Copies (VSS) to prevent easy restoration.
- 4) **Extortion:** A ransom note is generated, instructing the victim on how to pay (usually via cryptocurrency) to receive the decryption tool and the unique private key linked to their TRANSACTION ID.

In the context of this simulation, ShinoLocker perfectly demonstrates this behavior, utilizing the cryptographic principles of symmetric and asymmetric encryption to lock files and demanding interaction with its C2 infrastructure to facilitate the simulated extortion process.

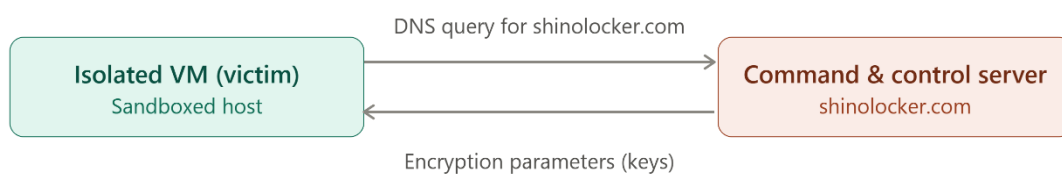
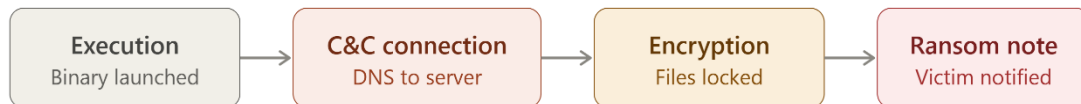
2.3. The ShinoLocker Ransomware Simulator

To analyze ransomware behavior without actually endangering data and infrastructure, simulators like ShinoLocker are used. This tool is designed for educational purposes and penetration testing. It mimics all the behaviors of real ransomware (like CryptoLocker), including communicating with a Command & Control (C&C) server, encrypting files, and generating a ransom note, with the difference that it provides the decryption key (K) to the researcher.

Phases and Operational Cycle of ShinoLocker:

1. **C2 Communication (Command & Control):** Upon execution, ShinoLocker communicates in the background with its C2 server (e.g., domains like `[shinolocker.com]` or `[shinosec.com]`). This communication is established to register the infection status and retrieve the encryption keys (K) or necessary parameters. This phase generates numerous DNS requests in the network.
2. **File Discovery:** The simulator searches the victim's operating system (including local and network drives) to find files with targeted extensions (like `[.docx]`, `[.pdf]`, `[.jpg]`) or specific pre-determined folders. During this phase, the OS experiences a high volume of `[ReadFile]` operations.
3. **Encryption Phase:** The discovered files (plaintext P) are read and converted into unreadable files (C) using standard cryptographic algorithms and the key K . The ransomware then changes the name or extension of the original files, which is recorded in the system as `[WriteFile]` and `[SetRenameInformationFile]` events.

4. **Ransom Note:** After encryption is complete, the tool places a text file or an HTML page on the victim's desktop or changes the desktop wallpaper to notify the user that their files are encrypted and what actions they must take to receive function D and key K .



2.3.1. ShinoLocker Configuration Parameters (Builder Interface)

Before generating the ransomware payload, ShinoLocker provides a builder interface that allows the operator to configure specific parameters. These text boxes define how the simulated ransomware will behave on the infected system:

- **Server URL:** This specifies the Command and Control (C2) server address (e.g., [https://shinolocker.com/]). The ransomware uses this URL to establish communication, register the infection, and exchange cryptographic keys (K).
- **User Agent:** This defines the HTTP User-Agent string the malware will use when communicating with the C2 server. By mimicking legitimate browsers (e.g., [Mozilla/5.0...]), the ransomware attempts to blend its network traffic with normal web browsing to evade network intrusion detection systems.
- **Extension to search the targeted file:** This text box contains a space-separated list of file extensions (e.g., [bmp jpg docx txt]). It dictates the scope of the encryption phase. The ransomware will only search for and encrypt files matching these specific extensions, typically targeting valuable personal or business data while leaving critical operating system files untouched to ensure the system remains bootable to display the ransom note.
- **Command & Parameter (delete Shadow Copy):** This is a critical ransomware behavior. The default command [vssadmin delete shadows /all /quiet] is executed to delete Windows Volume Shadow Copies. Shadow copies are automatic system backups. By deleting them, the ransomware ensures the victim cannot easily restore their files (P) using built-in Windows recovery tools, thereby forcing them to rely on the attacker's decryption tool.

- **Registry Key:** This specifies the path within the Windows Registry (e.g., [Software\ShinoLocker]) where the ransomware will store its configuration data, state information, or persistence mechanisms.

2.3.2. Decryption Identifiers

During the recovery phase, if a victim attempts to decrypt their files, ransomware typically utilizes specific identifiers to manage the transaction and key delivery:

- **HOST ID:** This is a unique identifier generated for the specific infected machine. Because the attacker encrypts many different machines, the C2 server needs to know exactly which machine is requesting decryption to provide the correct corresponding decryption key (K). The HOST ID ensures the victim receives the key that matches their specific ciphertext (C).
- **TRANSACTION ID:** This identifier is associated with the ransom payment process. It is used to track and verify that the victim has actually transferred the demanded cryptocurrency. Once the attacker verifies the payment linked to the specific TRANSACTION ID, they release the decryption key associated with the corresponding HOST ID.

2.4. The Role of Virtual Environments in Malware Analysis

Analyzing malware, particularly ransomware, inherently carries significant risks to data and infrastructure. If executed directly on a physical host machine, ransomware could encrypt critical personal or organizational files, compromise the operating system, and potentially propagate across the local network.

To mitigate these risks, this project was strictly conducted within a Virtual Machine (VM) environment. A VM provides a secure, isolated sandbox that completely contains the execution of the ShinoLocker simulator. This isolation prevents the ransomware from interacting with or damaging the underlying host system and its network environment. Furthermore, virtual environments offer snapshot capabilities, allowing analysts to quickly revert the system to a clean, pre-infection state. This feature is essential for conducting repeatable tests, safely observing malicious behaviors, and capturing clean logs (such as Procmon and Wireshark data) in a controlled setting without jeopardizing real-world assets.

3. Wireshark and Procmon Analysis

This section details the practical analysis of the simulated ransomware attack. By utilizing industry-standard monitoring tools, we can observe the exact network and endpoint behaviors exhibited by the ShinoLocker simulator during its execution cycle.

3.1. Overview of Monitoring Tools

To effectively analyze a malware infection, deep visibility into both network traffic and host-system activity is required. For this simulation, two primary tools were utilized:

- **Wireshark:** A widely used network protocol analyzer that captures and displays data packets traveling back and forth on a network in real-time. In malware analysis, Wireshark

is crucial for identifying suspicious outbound connections, Command and Control (C2) communications, and DNS queries made by the malicious payload.

- **Process Monitor (Procmon):** An advanced monitoring tool for Windows created by Sysinternals (Microsoft). It provides real-time visibility into file system, registry, and process/thread activity. Procmon is essential for tracking how ransomware interacts with the operating system, specifically identifying which files are being accessed, encrypted, and renamed.

3.2. Network Traffic Analysis (Wireshark Logs)

The first step in analyzing the ShinoLocker behavior is to inspect the network traffic generated immediately after execution. Ransomware typically needs to contact its C2 server to register the infection and retrieve encryption keys (*K*).

Steps for Analysis:

1. **DNS Query Inspection:** By applying the `[dns]` filter in Wireshark, we look for domain name resolutions requested by the victim machine. Normal traffic (like `[microsoft.com]` or `[bing.com]`) is ignored, while unknown or suspicious domains are flagged.
2. **Identifying C2 Domains:** During the simulation, specific DNS queries for `[shinolocker.com]` and `[shinosec.com]` were captured. These are the known C2 domains for this simulator.
3. **IP Address Extraction:** By examining the DNS response packets, the IP addresses associated with these domains were identified as `[188.166.237.163]` and `[128.199.83.111]`.
4. **Traffic Isolation:** Using a filter such as `[ip.addr == 188.166.237.163 or ip.addr == 128.199.83.111]`, we isolate the communication packets (HTTP or TLS handshakes) between the victim machine and the attacker's infrastructure, representing the exchange of encryption parameters.

3.2.1. Command and Control (C2) Discovery via DNS (filter: `[dns]`)

By filtering the DNS traffic originating from the victim machine (IP: `[10.0.2.15]`), the network communications of the ShinoLocker simulator were clearly identified. The malware initiated contact with its C2 server to register the infection and likely retrieve encryption parameters. Key forensic artifacts extracted from the logs include:

- **Primary Domain Identification:** At packet number `[2457]` of the capture, the victim machine sent a DNS query for the malicious domain `[shinolocker.com]`.
- **C2 Server IP Extraction:** At packet number `[6246]`, the local DNS resolver (IP: `[192.168.43.1]`) responded with an A record, resolving the malicious domain to the IPv4 address `[188.166.237.163]`. Discovering this IP address is a critical Indicator of Compromise (IoC) required for developing firewall blocking rules.
- **Infrastructure Verification (Reverse DNS):** The capture also logged a PTR record at packet number `[3500]`, linking the IP address back to `[shinolocker.com]`, confirming the dedicated nature of the attacker's infrastructure.

- **Secondary/Fallback Domains:** A subsequent DNS query was observed at packet number [7213] for the domain [shinosec.com]. This indicates that the ransomware utilizes alternative domains or fallback mechanisms to ensure sustained communication with its infrastructure if the primary domain is blocked.

No.	Time	Source	Destination	Protocol	Length	Info
2457	9.266493	10.0.2.15	192.168.43.1	DNS	75	Standard query 0xe855 AAAA shinolocker.com
3500	13.016497	192.168.43.1	10.0.2.15	DNS	117	Standard query response 0x39a0 PTR 163.237.166.188.in-addr.arpa PTR shinolocker.com
6246	24.098279	192.168.43.1	10.0.2.15	DNS	91	Standard query response 0xcc76 A shinolocker.com A 188.166.237.163
7213	26.666519	10.0.2.15	192.168.43.1	DNS	72	Standard query 0xf07c HTTPS shinosec.com

3.2.2. Analysis of C2 Traffic

Filter: `[ip.addr == 188.166.237.163 or ip.addr == 128.199.83.111]`

1) Primary C2 Server ([188.166.237.163] - shinolocker.com)

- **Protocol & Handshake:** The client initiates multiple TCP 3-way handshakes to port [443].
- **TLS Negotiation Issues:** Interestingly, the early connection attempts fail. Wireshark shows `[Alert (Level: Fatal, Description: Protocol Version)]`, indicating the malware and server initially struggled to agree on a TLS version, leading to immediate connection resets (FIN/ACK).
- **Successful Connection:** The malware is resilient. It retries and successfully negotiates a **TLSv1.2** connection.
- **SNI Leak:** During the “Client Hello” packet, the Server Name Indication (SNI) field is visible in plaintext, confirming the destination is [shinolocker.com].
- **Data Exchange:** Between [25.82] and [26.38], multiple encrypted `[Application Data]` packets are exchanged bidirectionally before the connection is closed by the client at [26.925]. A second connection attempt occurs later at [34.11].

2) Secondary/Fallback C2 Server ([128.199.83.111] - shinosec.com)

- **Protocol & Handshake:** Almost immediately after the primary C2 connection closes, the malware opens a new connection to the second IP at [27.301].
- **Modern Encryption:** This connection successfully negotiates using the newer, more secure **TLSv1.3**.
- **SNI Leak:** The SNI confirms this traffic is destined for [shinosec.com].
- **Data Exchange:** Encrypted `[Application Data]` is exchanged in an irregular pattern (at [28.39], [29.47], [31.16], and [33.67]). This prolonged, intermittent exchange is

highly indicative of the malware sending the encryption key, registering the victim's [HOST ID], or polling for further instructions.

Following the successful DNS resolutions, the network logs were analyzed to observe the malware's communication phase with its Command and Control infrastructure. By filtering for the resolved IP addresses ([188.166.237.163] and [128.199.83.111]), the exact mechanism of the C2 channel was isolated.

3.2.3. Encrypted Channel Establishment

The analysis confirms that ShinoLocker utilizes encrypted communications (HTTPS over TCP Port [443]) to mask its C2 traffic, preventing Deep Packet Inspection (DPI) from reading the payloads. Consequently, plaintext HTTP GET or POST requests were not observable; instead, the traffic manifests as encrypted [Application Data].

Despite the payload encryption, critical metadata was extracted from the TLS handshakes. Specifically, the Server Name Indication (SNI) field within the "Client Hello" packets cleanly mapped the IP addresses to their respective domains ([shinolocker.com] and [shinosec.com]).

3.2.4. C2 Infrastructure Resilience and Behavior

The packet capture reveals a sophisticated, multi-tiered C2 approach:

- 1) **Primary Communication:** The endpoint initially attempted to communicate with [188.166.237.163] ([shinolocker.com]). Packet logs show initial TLS protocol negotiation failures (Fatal Protocol Version Alerts), demonstrating the malware's built-in retry mechanisms. It eventually succeeded in negotiating a TLSv1.2 tunnel, exchanging several bursts of data before terminating the connection.
- 2) **Secondary/Fallback Communication:** Immediately following the primary data exchange, the malware initiated a secondary connection to [128.199.83.111] ([shinosec.com]). This connection utilized the more modern TLSv1.3 protocol. The staggered exchange of [Application Data] over several seconds ([28.39] to [33.67]) strongly suggests the transmission of the victim's unique [HOST ID] and the generated encryption keys, or a beaconing process to verify payment status ([TRANSACTION ID]).

The use of standard HTTPS port [443], coupled with robust TLS encryption and redundant infrastructure, highlights the malware's design to blend in with normal web traffic. Since the payload cannot be decrypted without the session keys (e.g., via an SSLKEYLOGFILE), perimeter defenses must rely on blocking the identified SNIs and IP addresses rather than relying on payload signature matching.

3.3. Endpoint Behavior & File Encryption Analysis (Procmon Logs)

While Wireshark shows us the external communication, Procmon reveals the internal damage. We analyze the Procmon logs to observe the encryption phase on the local disk.

Steps for Analysis:

- 1) **Applying Path Filters:** To isolate the ransomware's activity from normal OS noise, targeted filters were applied based on the Process Name ([shinolocker.exe]) and

critical operations like `[SetRenameInformationFile]`. This strategy ensured an accurate capture of the ransomware’s complete execution lifecycle, including its secondary dropped payloads.

- 2) **Isolating File System Activity:** Registry and Network monitoring are toggled off in the Procmon toolbar, leaving only “Show File System Activity” enabled.
- 3) **Tracking the Encryption Cycle:** The logs are analyzed for a specific sequence of operations performed by the ShinoLocker process:
 - **[ReadFile]:** The ransomware reads the contents of the original target file (Plaintext *P*).
 - **[WriteFile]:** The ransomware writes the newly encrypted data (Ciphertext *C*) back to the disk.
 - **[SetRenameInformationFile]:** The ransomware changes the file extension of the original file (e.g., from `[.docx]` to a locked extension) to indicate it has been encrypted. This operation is a critical Indicator of Compromise (IoC) at the endpoint level. By appending a specific extension (e.g., `[.shino]`), the ransomware flags the file as encrypted and readies it for the extortion phase. In Procmon, the ‘Detail’ column for this event explicitly shows the target modified filename.

Analysis of the Process Monitor (Procmon) logs revealed the local execution chain and file system manipulation tactics employed by the ShinoLocker simulator. The malware utilized a multi-stage approach to evade simple process-based detection.

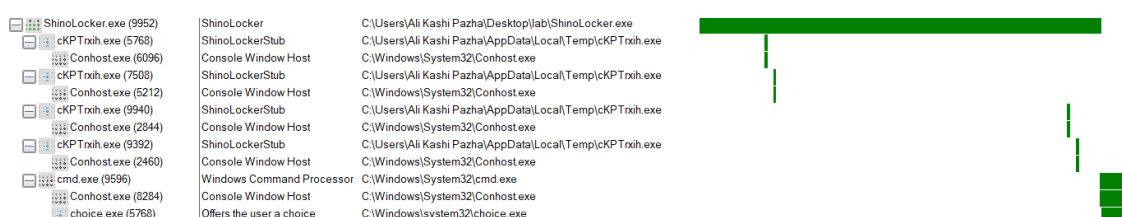
3.3.1. Target Enumeration and Staging

Based on the `[procmon_shinolocker_log.PML]` log (provided in `[.\logs\procmon]` directory), the initial executable, `[ShinoLocker.exe]` (PID [9952]), did not directly perform encryption on the target files. Instead, it engaged in directory traversal and enumeration. During this phase, it actively wrote to a temporary staging file located at `[C:\Users\Ali Kashi Pazha\AppData\Local\Temp\bQXEbM.1st]`

This `[.1st]` file was written sequentially and served as a target list containing the paths of the files destined for encryption. This behavior highlights the malware’s modular design, separating the discovery phase from the destructive phase.

3.3.2. Execution via Dropped Payload

The actual file manipulation was delegated to a secondary, randomly named executable. The `[procmon_SetRenameInformationFile_log.PML]` log (provided in `[.\logs\procmon]` directory) demonstrates that the `[SetRenameInformationFile]` operations were executed by a process named `[cKPTrxih.exe]`, not the original ShinoLocker process. Using randomly generated filenames for payloads is a common evasion technique designed to bypass static signature-based detections and confuse endpoint analysts.



```

"C:\Users\Ali Kashi Pazha\Desktop\lab\ShinoLocker.exe"
"C:\Users\Ali Kashi Pazha\AppData\Local\Temp\cKPTrxih.exe" E Wez03hsEhpTFfcIBCH1CnQ== D91JCmhNvM0wulmxRf7PuQ== "C:\Users\Ali Kashi Pazha\Desktop\target_files\dummy.png"
{??}C:\Windows\system32\conhost.exe 0x00000000-ForceV1
"C:\Users\Ali Kashi Pazha\AppData\Local\Temp\cKPTrxih.exe" E Wez03hsEhpTFfcIBCH1CnQ== D91JCmhNvM0wulmxRf7PuQ== "C:\Users\Ali Kashi Pazha\Desktop\target_files\dummy.docx"
{??}C:\Windows\system32\conhost.exe 0x00000000-ForceV1
"C:\Users\Ali Kashi Pazha\AppData\Local\Temp\cKPTrxih.exe" D Wez03hsEhpTFfcIBCH1CnQ== D91JCmhNvM0wulmxRf7PuQ== "C:\Users\Ali Kashi Pazha\Desktop\target_files\dummy.png shino"
{??}C:\Windows\system32\conhost.exe 0x00000000-ForceV1
"C:\Users\Ali Kashi Pazha\AppData\Local\Temp\cKPTrxih.exe" D Wez03hsEhpTFfcIBCH1CnQ== D91JCmhNvM0wulmxRf7PuQ== "C:\Users\Ali Kashi Pazha\Desktop\target_files\dummy.docx shino"
{??}C:\Windows\system32\conhost.exe 0x00000000-ForceV1
"C:\Windows\System32\cmd.exe" /C choice /C Y /N /D Y /T 3 & Del C:\Users\Ali Kashi Pazha\Desktop\lab\ShinoLocker.exe
{??}C:\Windows\system32\conhost.exe 0x00000000-ForceV1
choice /C Y /N /D Y /T 3

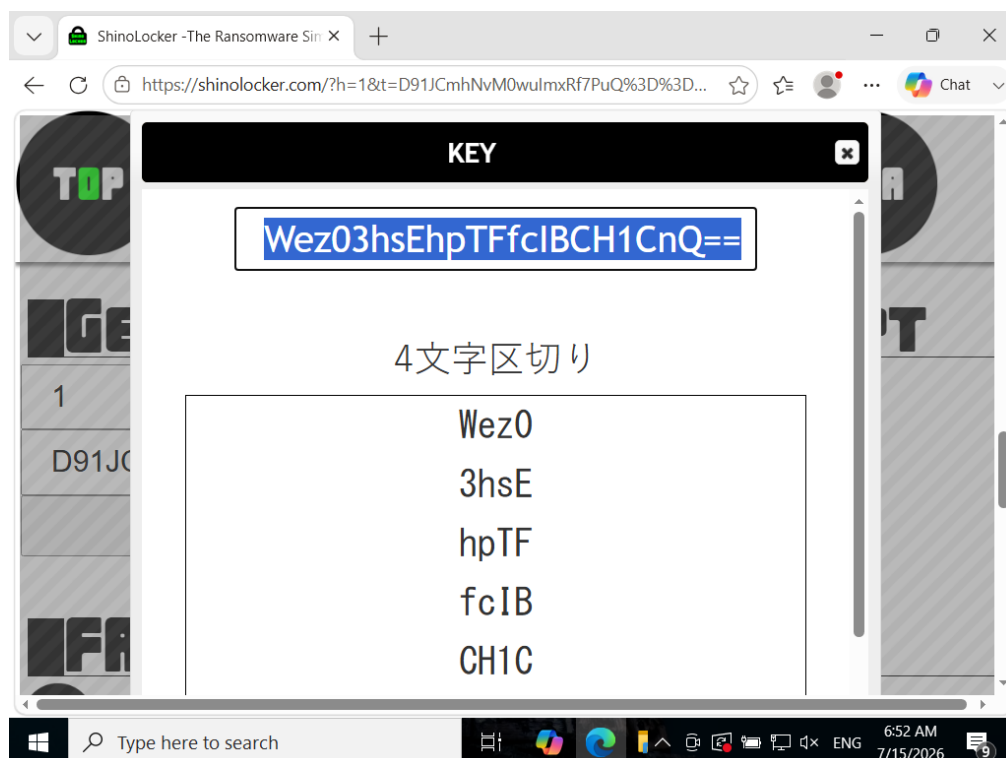
```

Analysis of the process execution flow reveals that the primary executable, [ShinoLocker.exe], acts as an orchestrator. It executes the dropped payload, [cKPTrxih.exe], multiple times, passing critical cryptographic parameters via command-line arguments for each target file. The command structure follows a distinct pattern; specifying an operation flag ('E' for encrypt, 'D' for decrypt), the encryption key, a unique victim identifier token, and the absolute path to the target file. The command structure is as follows:

[cKPTrxih.exe [Action_Flag] [Encryption_Key] [Victim_ID] [Target_File_Path]]

A critical finding from the command-line analysis is the direct correlation between the parameters passed to the payload and the data managed by the Command and Control (C2) infrastructure. Specifically, the encryption key observed in the command-line arguments ([Wez03hsEhpTFfcIBCH1CnQ==]) perfectly matches the decryption key displayed on the ShinoLocker web interface. This definitively proves that the primary ransomware executable retrieves the key from the C2 server and passes it in plaintext to the child process ([cKPTrxih.exe]) responsible for the actual encryption phase.

Furthermore, the victim identifier token passed in the command line ([D91JCmhNvM0wulmxRf7PuQ==]) corresponds exactly to the [t=] parameter found in the URL of the attacker's web panel. This direct mapping not only illustrates how the malware tracks individual infections but also provides concrete evidence of the communication channel and data synchronization between the local execution environment and the remote C2 server.



At the end, upon completing the file operations, [ShinoLocker.exe] initiates a self-deletion routine. It spawns [cmd.exe] utilizing the [choice] command to introduce a brief delay ([/T 3]) before executing a [Del] command to securely remove the original malware binary from the disk, a classic anti-forensic technique employed to evade detection and hinder post-incident analysis.

3.3.3. The Encryption and Deletion Phase

The Procmon logs successfully captured the final stages of the ransomware lifecycle. The secondary process ([cKPTrxih.exe]) performed the following actions on the target directory ([C:\Users\Ali Kashi Pazha\Desktop\target_files]):

- 1) **Original File Deletion/Move:** The original unencrypted files (e.g., [dummy.jpg], [dummy.docx]) were moved to the Windows Recycle Bin ([C:\Recycle.Bin\...]) and renamed with system-generated deletion tags (e.g., [RJELIQG.jpg]). Moving or securely wiping original files ensures the victim cannot easily restore them without the decryption key.
- 2) **File Extension Modification:** The logs confirm the presence of new files appended with the [.shino] extension (e.g., [dummy.jpg.shino], [dummy.docx.shino]). This is the definitive indicator of compromise (IoC) at the endpoint level, confirming the successful generation of encrypted ciphertext files.

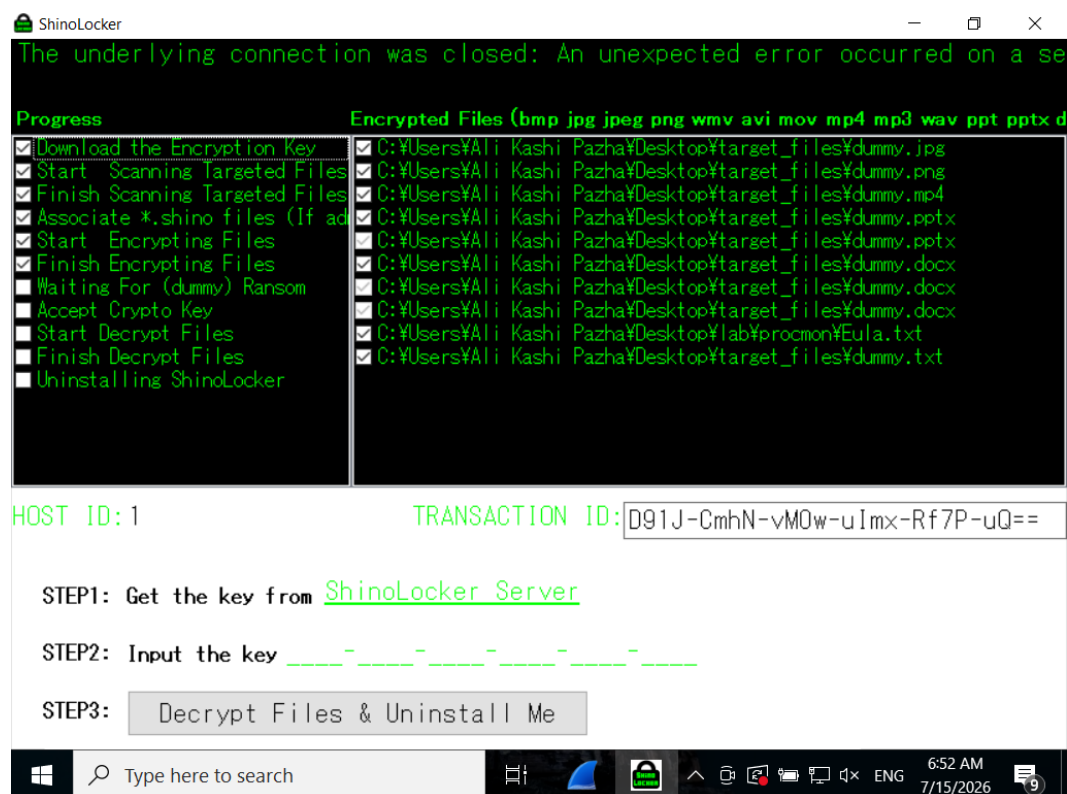
3.3.4. Endpoint Indicators of Compromise (IoCs)

An Indicator of Compromise (IoC) is a forensic artifact or an observable piece of data found on a network or operating system that strongly suggests a computer intrusion or malicious activity has occurred. In the context of ransomware analysis, IoCs act as digital breadcrumbs—such as specific file extensions, known malicious IP addresses, temporary staging files, or randomly generated executable names—that security analysts and automated defense systems use to detect, contain, and remediate the threat effectively.

IoC Type	Value	Description
Dropped File / Staging	[bQXEbM.lst]	Temporary file list created in [TEMP] by ShinoLocker.
Malicious Process	[cKPTrxih.exe]	Randomly named payload responsible for file manipulation.
File Extension	[.shino]	Suffix appended to encrypted files (e.g., [dummy.jpg.shino]).

3.4. Identifying Ransom Note Generation

The final step of the ransomware kill chain is notifying the victim.



4. Mitigation and Defense Strategies

Based on the forensic analysis of network traffic and endpoint behavior during the ShinoLocker simulation, several critical defense gaps were identified. This section outlines the recommended mitigation strategies, ranging from immediate network-level blocking to long-term system hardening, to prevent or disrupt a real-world ransomware infection.

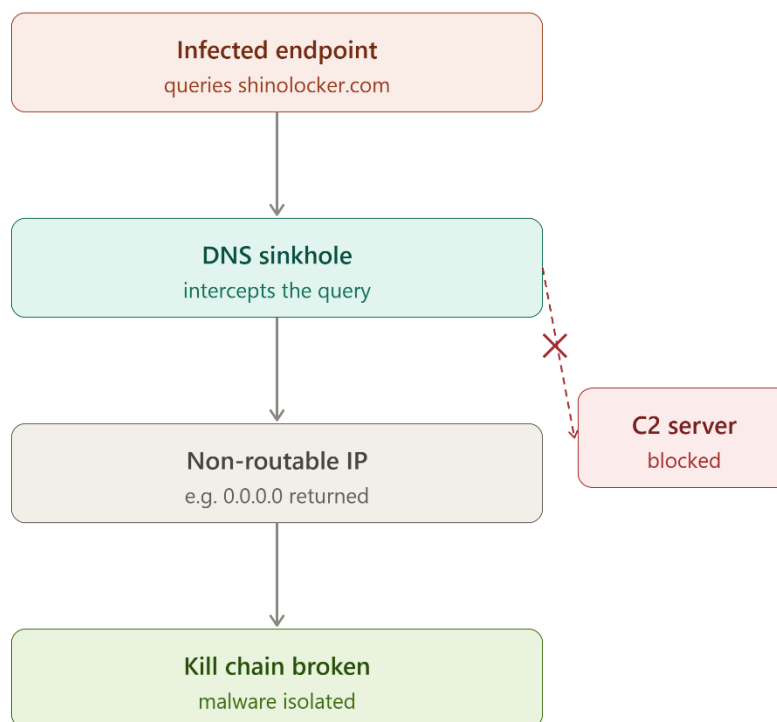
4.1. Network-Level Defenses and IoC Utilization

The analysis of the Wireshark DNS logs provided actionable intelligence that is crucial for building a resilient network defense. Relying on the assumption that “malware communicates with a server” is insufficient; concrete data must be utilized to block the attack kill chain.

4.1.1. Implementing DNS Filtering and Sinkholing

During the simulation, the local gateway (IP: [192.168.43.1]) successfully resolved the malicious domains without triggering any alerts or blocks. This highlights a significant defense gap: the absence of DNS filtering.

To mitigate this, organizations must implement DNS Sinkholing or enterprise DNS filtering solutions (e.g., Cisco Umbrella). If a DNS filter had been in place, the initial query at timestamp [9.266493] would have been blocked or redirected to a safe, controlled IP address, effectively severing the malware’s connection to its Command and Control (C2) server before encryption keys could be exchanged.



4.1.2. Proactive IoC-Based Firewall Blocking

Extracting Actionable Indicators of Compromise (IoCs) from the logs allows for the creation of precise firewall rules. The log analysis revealed not only the primary domain but also the malware's resilience mechanisms. The secondary query for [shinosec.com] demonstrated that blocking a single domain is insufficient, as the malware utilizes fallback infrastructure.

To ensure comprehensive blocking, all extracted IoCs must be ingested into the perimeter firewall and Intrusion Prevention Systems (IPS):

Indicator Type	Value	Action Required
Domain	[shinolocker.com]	Block/Drop Traffic, Alert
Domain	[shinosec.com]	Block/Drop Traffic, Alert
IPv4 Address	[188.166.237.163]	Block/Drop Traffic, Alert
IPv4 Address	[128.199.83.111]	Block/Drop Traffic, Alert

4.2. Kill Chain Disruption Based on Attack Timeline

The timestamps extracted from the Wireshark and Procmon logs provide a precise timeline of the attack. Network defenders can use this timeline to implement automated orchestration. By detecting the C2 communication phase (identified at [9.266493]), Endpoint Detection and

Response (EDR) systems can automatically isolate the infected host from the network. Because there is a measurable delay between the DNS resolution and the actual `[WriteFile]` operations (the encryption phase), detecting and reacting to the initial network anomaly is the most effective way to save the data before it is destroyed.

4.3. Endpoint Hardening and Attack Surface Reduction

Beyond network defenses, reducing the endpoint's attack surface is the quickest and easiest mitigation strategy to implement against ransomware propagation.

4.3.1. Disabling Vulnerable Services (SMB and RDP)

Ransomware often moves laterally across a network by exploiting Server Message Block (SMB) or Remote Desktop Protocol (RDP) vulnerabilities. The fastest mitigation is to restrict or disable these services if they are not strictly required for business operations.

Instead of relying solely on Windows Defender Firewall—which can sometimes be disabled by advanced malware—administrators can enforce restrictions via PowerShell scripts or Group Policy Objects (GPO) directly at the service level:

- Disabling the SMB Server service (`[LanmanServer]`).
- Disabling RDP connections via the `[fDenyTSConnections]` registry key.

```
PS C:\Users\Ali Kashi Pazha> Stop-Service -Name LanmanServer -Force
PS C:\Users\Ali Kashi Pazha> Set-Service -Name LanmanServer -StartupType
Disabled
PS C:\Users\Ali Kashi Pazha> Set-ItemProperty -Path
"HKLM:\System\CurrentControlSet\Control\Terminal Server" -Name
"fDenyTSConnections" -Value 1
```

4.3.2. Data Resilience through Offline Backups

While Virtual Machines (VMs) and snapshots provide a secure sandbox for simulation, they do not constitute true data backups. Ransomware can encrypt local backups and network-attached storage. The most reliable defense against data loss is maintaining genuine Offline Backups. This requires copying critical data to a physical storage medium that is completely disconnected from the network and the host system (air-gapped) when not in active use, ensuring the ransomware cannot reach it.

4.4. The Role of Native OS Defenses: Mitigating Ransomware Threats

At the beginning of this analysis, the Windows `[virus & threat protection]` and `[Firewall & network protection]` settings were intentionally disabled. This is a standard procedure in malware analysis sandboxes to allow the malicious payload to execute fully, enabling researchers to observe its entire lifecycle, network communications, and file system modifications without interruption. However, in a real-world environment, these built-in security features act as the primary line of defense against ransomware attacks, including simulators like ShinoLocker.

4.4.1. Virus & Threat Protection (Endpoint Antivirus)

Windows Defender Antivirus (and similar EDR solutions) utilizes multiple layers of analysis to detect and neutralize ransomware before it can encrypt user data:

- **Signature-Based Detection:** Antivirus engines maintain a massive database of known malware hashes and signatures. If a user attempts to download or execute [`ShinoLocker.exe`] (or any known malicious variant), the AV will instantly quarantine the file based on its known malicious hash.
- **Heuristic and Behavioral Monitoring:** Modern ransomware often evades signature detection through obfuscation or packing. To counter this, the OS monitors runtime behavior. When [`ShinoLocker.exe`] drops secondary payloads (like [`cKPTrxih.exe`]) and initiates rapid, mass file modification operations (such as the continuous [`SetRenameInformationFile`] events observed in Procmon), the behavioral engine flags this as anomalous and terminates the process tree immediately.
- **Controlled Folder Access (Anti-Ransomware Feature):** This specific Windows Defender feature protects designated folders (such as Documents, Pictures, and Desktop). If an unauthorized or untrusted application attempts to modify or encrypt files within these directories, the OS strictly blocks the action. This feature alone would prevent ShinoLocker from successfully altering the victim's personal files, even if the executable managed to run.
- **Cloud-Delivered Protection:** By leveraging machine learning models and global threat intelligence, Windows Security can upload suspicious files or metadata to the cloud for real-time analysis, effectively blocking zero-day ransomware variants within milliseconds based on their structure and intended API calls.

4.4.2. Firewall & Network Protection

Ransomware relies heavily on network communications for key exchange, Command and Control (C2) instructions, and lateral movement. The host-based firewall disrupts these critical phases:

- **Blocking Outbound C2 Traffic:** ShinoLocker requires communication with its servers ([`shinolocker.com`], [`shinosec.com`]) to register the Victim ID and retrieve the encryption key. A properly configured firewall, especially when integrated with threat intelligence, can block outbound connections to newly registered, suspicious, or known malicious IP addresses (e.g., [`188.166.237.163`] or [`128.199.83.111`]). Without the key from the C2 server, the encryption sequence cannot proceed.
- **Application-Level Traffic Filtering:** The firewall monitors which applications are requesting network access. A sudden outbound HTTP/HTTPS request from an unknown, unsigned executable running from a temporary directory (like AppData or Temp) often triggers an alert or an automatic block, severing the ransomware's connection to its infrastructure.
- **Preventing Lateral Movement (Network Spreading):** Many modern ransomware families attempt to spread across the local network by exploiting vulnerabilities in protocols like SMB (Port 445) or RDP (Port 3389). The Windows Firewall rules block unsolicited inbound traffic to these ports by default on Public and Private network

profiles, effectively isolating the infection to a single machine and protecting the broader network infrastructure.

The execution, communication, and encryption cycle observed during this ShinoLocker analysis was only possible because the foundational OS security layers were bypassed. In a production environment, the combination of behavioral monitoring, anti-ransomware folder protection, and strict network traffic regulation forms a highly effective barrier against such threats.

For further details and complete logs, refer to the following files:

```
.\\logs\\wireshark\\ wireshark_log.pcapng  
.\\logs\\procmon\\ procmon_shinolocker_log.PML  
.\\logs\\procmon\\ procmon_SetRenameInformationFile_log.PML
```